

Comment Claude Code isole ses opérations au niveau OS

Principe : l'OS comme périmètre de sécurité

Depuis v2.1.0, Claude Code intègre un sandbox natif qui isole l'exécution des commandes bash au niveau du noyau. L'idée centrale est d'inverser la logique habituelle : plutôt que de valider chaque commande par une confirmation utilisateur, on laisse Claude opérer librement à l'intérieur de frontières OS-enforced. Le sandbox devient le gardien, pas le système de permissions.

Activation : `/sandbox` dans Claude Code (menu interactif).

Primitives OS selon la plateforme

macOS : Seatbelt. Intégré au système, aucune installation requise. Utilise le framework TrustedBSD Mandatory Access Control pour filtrer les appels système au niveau kernel. Overhead minimal (~1-2% CPU).

Linux / WSL2 : bubblewrap. Nécessite l'installation de deux paquets.

```
sudo apt-get install bubblewrap socat # Ubuntu/Debian
sudo dnf install bubblewrap socat # Fedora
```

Crée un namespace isolé (mount, network, PID, IPC) pour chaque commande exécutée. Overhead comparable (~2-3% CPU, moins de 10ms de démarrage par commande).

WSL1 : non supporté. **Windows natif** : planifié, pas encore disponible.

Isolation filesystem

La politique par défaut est asymétrique et intentionnelle : lecture sur tout le système, écriture restreinte au répertoire de travail courant (CWD) et ses sous-dossiers.

Accès	Périmètre
Lecture	Tout l'ordinateur (sauf deny rules)
Écriture	CWD et sous-dossiers uniquement
Exécution	Commandes dans l'environnement sandboxé

Pour restreindre la lecture de répertoires sensibles (SSH, credentials cloud), utiliser les `permissions.deny` dans `settings.json` :

```
{  "permissions" : {    "deny" : [      "Read(~/.ssh/**)",      "Read(~/.aws/**)",      "Edit(~/.ssh/**)",      "Edit(~/.aws/**)"    ]  } }
```

Isolation réseau

Toutes les connexions réseau des commandes sandboxées passent par un proxy SOCKS5 qui tourne hors sandbox. Le proxy applique un filtrage par domaine sans inspecter le contenu du trafic (pas de deep packet inspection).

Configuration : mode `deny` (bloquer tout sauf liste blanche) ou mode `allow` (autoriser tout sauf liste noire).

```
{  "sandbox" : {    "network" : {      "policy" : "deny",      "allowedDomains" : [        "api.anthropic.com",        "*.npmjs.org",        "github.com"      ]    }  } }
```

Deux modes de fonctionnement

Auto-allow : les commandes bash dans le sandbox sont automatiquement approuvées. Les commandes incompatibles avec le sandbox (ex : `docker`) déclenchent un fallback vers le flux de permissions normal. Recommandé pour le développement quotidien.

Regular permissions : même dans le sandbox, chaque commande demande une approbation explicite. Utile pour les environnements haute sécurité ou les codebases non fiables.

L'escape hatch : `dangerouslyDisableSandbox`

Certains outils sont incompatibles avec le sandboxing car ils nécessitent un accès à des ressources système spécifiques (`docker` via `/var/run/docker.sock`, `watchman` via les filesystem watch APIs). Claude détecte l'échec, relance la commande avec ce paramètre, et demande confirmation à l'utilisateur. Pour désactiver complètement l'escape hatch dans les environnements critiques :

```
{  "sandbox" : {    "allowUnsandboxedCommands" : false,    "failIfUnavailable" : true  } }
```

`failIfUnavailable: true` (v2.1.78+) : fait échouer la session si le sandbox ne peut pas démarrer, plutôt que de continuer sans isolation. Recommandé pour les environnements de production.